

### **Title**

Compliance Assessment using Test of Design (ToD) and Test of Operational Effectiveness (ToOE)

### **Aim**

To perform a compliance assessment in Eramba by evaluating compliance requirements through Test of Design (ToD) and Test of Operational Effectiveness (ToOE) and linking them with policies, controls, and risks.

### **Procedure**

1. Log in to the Eramba GRC platform.
2. Navigate to **Compliance Management** → **Compliance Packages**.
3. Create a compliance package named *Exp 9 Information Security Compliance Assessment*.
4. Add compliance requirements to the package using the *Compliance Package Items* section.
5. Import/configure 20 compliance items covering areas such as access control, data protection, incident management, vulnerability management, backup, and business continuity.
6. Navigate to **Compliance Management** → **Compliance Analysis**.
7. Select the created compliance package and view the compliance requirements.
8. Open a compliance item such as **DP-02 – Data Retention**.
9. Configure the Compliance Strategy as *Compliant* and assign the responsible owner.
10. Link relevant internal controls, policies, and business risks to the compliance item.
11. Document the Test of Design (ToD), verifying that the required policy/process is properly designed and documented.
12. Document the Test of Operational Effectiveness (ToOE), verifying that the control is actually operating and supporting evidence exists.
13. Save the compliance assessment and review the resulting compliance status.

### **Output**

A compliance package containing 20 requirements was created and assessed. The selected compliance requirement was configured with a compliance strategy, owner, supporting controls, policies, and related risks. ToD and ToOE procedures were documented for evaluating both the design and actual operation of the compliance control.

Compliance Analysis

Exp 9 Inform... 20

Views

+

Filter

Sort

Columns

| <input type="checkbox"/> | Dynamic Status | Item ID | Item Name                    | Item Description                                                                          | Compliance Strategy |
|--------------------------|----------------|---------|------------------------------|-------------------------------------------------------------------------------------------|---------------------|
| <input type="checkbox"/> | <div></div>    | DP-02   | Data Retention               | Information shall be retained and securely disposed of according to defined requirements. | Compliant           |
| <input type="checkbox"/> | <div></div>    | BC-01   | Business Continuity Plan...  | Critical business process...                                                              |                     |
| <input type="checkbox"/> | <div></div>    | PS-01   | Physical Access Control      | Access to restricted area...                                                              |                     |
| <input type="checkbox"/> | <div></div>    | TP-02   | Third-Party Security Clau... | Security requirements sh...                                                               |                     |
| <input type="checkbox"/> | <div></div>    | TP-01   | Supplier Security Assess...  | Relevant suppliers shall b...                                                             |                     |
| <input type="checkbox"/> | <div></div>    | IM-03   | Incident Response Testing    | Incident response proced...                                                               |                     |
| <input type="checkbox"/> | <div></div>    | IM-02   | Incident Reporting           | Security incidents shall b...                                                             |                     |
| <input type="checkbox"/> | <div></div>    | SA-01   | Security Awareness Train...  | Personnel shall receive s...                                                              |                     |
| <input type="checkbox"/> | <div></div>    | BR-02   | Backup Restoration Testing   | Backup restoration shall b...                                                             |                     |

Go to Settings to activate Windows

Screenshot 1: Compliance Analysis showing the list of compliance requirements

< Back

20

Item detail

Compliance Item Details

|                             |                                                                                                                          |
|-----------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Item ID                     | DP-02                                                                                                                    |
| Item Name                   | Data Retention                                                                                                           |
| Item Description            | Information shall be retained and securely disposed of according to defined requirements.                                |
| Item Additional Information | ToD: Verify retention and disposal requirements are documented.<br>ToOE: Review retention records and disposal evidence. |

General

|                     |             |
|---------------------|-------------|
| Dynamic Status      |             |
| Compliance Strategy | Compliant   |
| Owner               | Admin Admin |
| Findings            |             |

Screenshot 2: DP-02 – Data Retention Item Details with ToD/ToOE information, strategy, and owner

| Treatment            |                                            |
|----------------------|--------------------------------------------|
| Internal Controls    | Backup and Recovery    Firewall Management |
| Policies             | Access Control Policy    Password Policy   |
| Compliance Exception |                                            |
| Projects             |                                            |
| Risks                |                                            |
| Asset Risks          |                                            |
| Third Party Risks    |                                            |
| Business Risks       | Data Breach    Unauthorized Access         |
| Liabilities          | Employee Data                              |

Screenshot 3: Treatment and Risks configuration showing linked controls, policies, business risks, and liabilities

Result

The compliance assessment was successfully configured in Eramba. The system demonstrated how compliance requirements can be evaluated through Test of Design and Test of Operational Effectiveness and connected to organizational controls, policies, and risks.